WBMME SECURITY VALIDATION

Summary Report | SV-01 to SV-10

1. Overview

This report summarises the security checks performed on WBMME, covering authentication, HTTPS, uploads, model artifacts, access control, request limits, sessions, CSRF, and security scanning.

2. Results

ID	Check	Status	Result
SV-01	Password security	**PASS**	42 authentication tests passed.
SV-02	HTTPS and TLS	**PASS**	HTTPS redirect, TLS 1.2/1.3 and cookie flags verified.
SV-03	Upload validation	**PARTIAL**	Invalid uploads rejected; export formula neutralisation pending US-26.
SV-04	Model artifact security	**PASS**	9 artifact security tests passed.
SV-05	Data isolation and audit logs	**PASS**	52 ownership and audit tests passed.
SV-06	Request and job limits	**PASS**	25 limit tests and 1 timeout test passed.
SV-07	Session and login security	**PASS**	12 session tests and 10 throttling tests passed.
SV-08	CSRF protection	**PASS**	Missing-token requests rejected; valid-token request accepted.
SV-09	OWASP ZAP scan	**PASS***	0 High, 1 Medium, 6 Low and 5 Informational findings.
SV-10	Static analysis (Bandit)	**PASS**	0 Medium and 0 High findings; all 4 CI checks green.

*SV-09 met the zero-High-finding criterion for the scan performed. The Medium CSP finding remains open for review.

3. Pending Items

- SV-03: Complete CSV export formula neutralisation after US-26 is merged, then rerun the export test.
- SV-09: Review the Medium Content Security Policy finding and the remaining lower-severity observations.
- SV-10: Bandit CI currently checks Medium and High severity findings; 893 Low findings were reported in the full scan.

4. Conclusion

Nine checks passed within the tested scope. SV-03 is partially complete because export formula neutralisation is pending. This report records the tests performed and does not represent a guarantee that the application is free of vulnerabilities or a production security certification.

5. Evidence

- Automated test results from the accounts, training, audit and datasets test suites.
- OWASP ZAP baseline workflow and its GitHub Actions report artifact.
- Bandit scan and CI workflow: .github/workflows/tests.yml.
- SV-10 commit: e4cea3b (feature/sv10-bandit-ci).